AWS SAA（SAA-C03）　分野1 セキュアなアーキテクチャの設計　#02

マルチアカウントとフェデレーション

アカウントをまとめて縛る。社員とアプリの利用者を、外の ID のままつなぐ

各ページの下に、根拠にした AWS の公式ドキュメント（Organizations・Control Tower・IAM Identity Center・Directory Service・Cognito など）を書いた（青い文字を押すと開く）。「」の中はドキュメントの原文どおり。会社名や場面は Claude が作った例

全体像 試験ガイド タスク 1.1 の後半

1 組織とアカウント
Organizations で束ねる。OU で分ける。管理アカウントには作業用のリソースを置かない

2 ガードレール
SCP（自分の組織の人の上限）・RCP（自分の組織のリソースの上限）・Control Tower

3 社員の ID
IAM Identity Center ＋ 権限セット。ID ソースは AD や外部 IdP

4 アプリの利用者の ID
Cognito：ユーザープール＝だれか（認証）、ID プール＝何を使えるか（認可）

タスク 1.1 の知識・スキル（要約）	このPDF
複数のアカウントにまたがるアクセス制御と管理	第1・2章
複数アカウントのセキュリティ戦略（Control Tower・SCP）	第2章
フェデレーションアクセスと ID サービス（IAM・Identity Center）	第3章
Directory Service を IAM ロールでフェデレートする場面	第3章
AWS 責任共有モデル	第2章
Cognito（タスク 1.2 のセキュリティサービス）	第3章

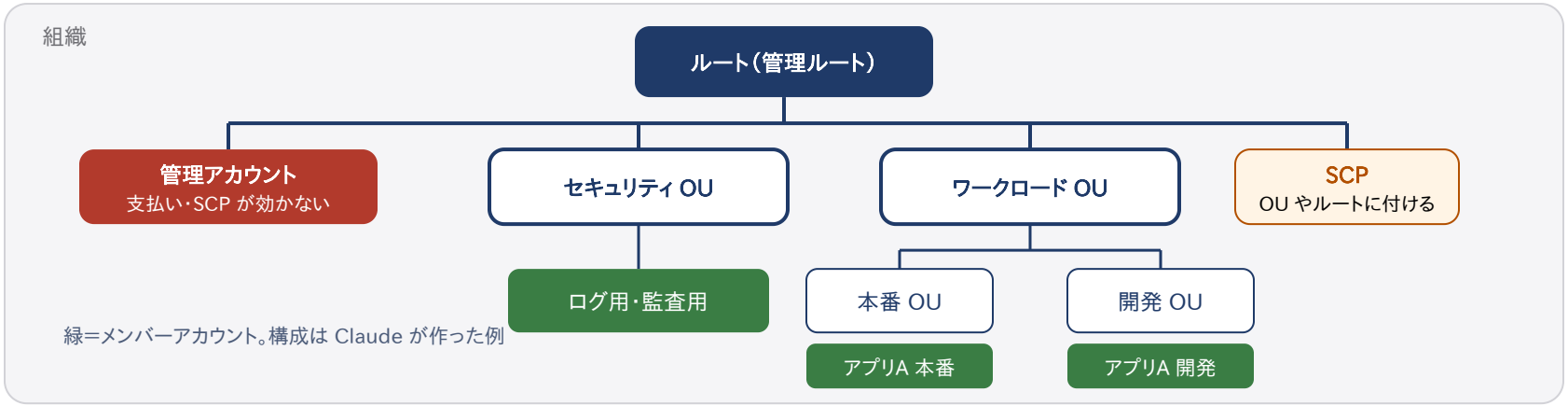
出典：AWS「コンテンツ分野 1: セキュアなアーキテクチャの設計」タスク 1.1・1.2

第1章

組織とアカウント

アカウントは、権限・セキュリティ・コストの境界。分けて、束ねる。

Organizations の木の形



部品	決まり
ルート	組織に1つ。自動でできる。#01 のルートユーザーとは別物
OU	アカウントのグループ。入れ子にできる。付けたポリシーは下のアカウントすべてに効く
メンバーアカウント	一度に1つの組織にだけ入れる。新しく作るか、招待して入れる

出典：AWS Organizations の概念と用語（組織構造・「ルートは 1 つのみ持つことができます。」「メンバーアカウントは、一度に 1 つの組織のみに所属できます。」）

管理アカウントは「組織の管理だけ」に使う

	管理アカウント	メンバーアカウント
役割	組織を作る・アカウントを作る／招待する・ポリシーを付ける	ワークロードを動かす
料金	全員分を払う（支払者）	管理アカウントにまとまる
SCP	効かない	効く（ルートユーザーも）
ほかに変更	できない	—

SCP で守れないので、管理アカウントに作業用のリソースを置かない。リソースはメンバーアカウントに分けるのが AWS のおすすめ。

機能のセット	使えること
すべての機能（既定・推奨）	一括請求に加えて、SCP などのポリシー、ほかのサービスとの統合、委任
一括請求だけ	請求をまとめるだけ。SCP は使えない

一括請求だけ → すべての機能に変えるには、招待で入ったメンバーアカウントすべての承認が要る。

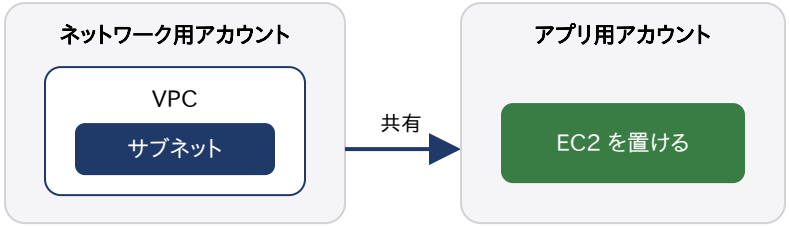
委任管理者	中身
Organizations の	組織のポリシーの管理を任せる
AWS サービスの	GuardDuty など統合したサービスの管理を任せる

委任管理者はメンバーアカウントなので SCP が効く。

出典：AWS Organizations の概念と用語（管理アカウント・利用可能な機能セット・委任された管理者）／サービスコントロールポリシー (SCP)（「SCP は、管理アカウントのユーザーやロールには影響を与えません。」）

アカウントをまたいで「そろえる」「分け合う」

AWS RAM（Resource Access Manager）



リソースごとにリソースベースのポリシーを書かなくても、アカウント・OU・組織全体と共有できる。代表例は VPC のサブネット、Transit Gateway、Route 53 Resolver のルール。

タグポリシー

そろえる前	タグポリシーで
costcenter / Cost-Center / CostCenter	CostCenter に統一

組織のアカウントのリソースに付けるタグを標準化する（キーや値の大文字・小文字など）。コスト配分タグ（#23）の集計がずれない。

> **似たものの見分け：**そろえる＝タグポリシー、止める＝SCP、分け合う＝RAM、アカウントを束ねる＝Organizations。

出典：AWS RAM とは／ポリシーとアクセス許可（AWS RAM リソース共有の一般的なユースケース）／タグポリシー

第2章

ガードレール：SCP・RCP・Control Tower

アカウントの管理者でも外せない「上限」を、上の階層からかける。

SCP：権限は与えない。上限だけ



実際の権限＝SCP（と RCP）が許す範囲と、ID ベース・リソースベースのポリシーが許す範囲の共通部分。図は Claude が作った模式図。

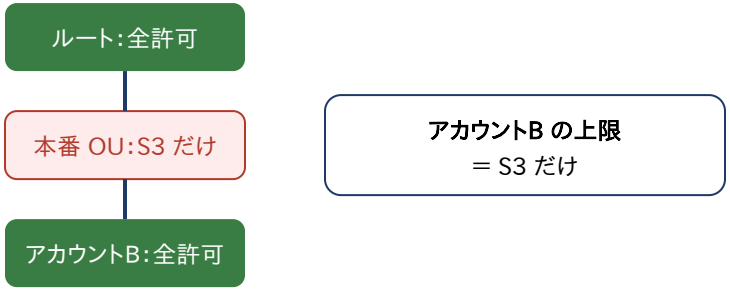
だれに効くか	SCP
メンバーアカウントの IAM ユーザー・ロール	効く
メンバーアカウントのルートユーザー	効く
委任管理者のアカウント	効く
管理アカウント	効かない
サービスにリンクされたロール	効かない
組織の外のユーザー・ロール	効かない（→ RCP）

> **IAM のポリシーがないユーザーは、SCP がすべてを許していても何もできない。**SCP は「開ける」ものではない。

出典：サービスコントロールポリシー (SCP)（「SCP は、組織内の IAM ユーザーと IAM ロールにアクセス許可を付与しません。」「SCP はサービスにリンクされたロールに影響***しません***。」）

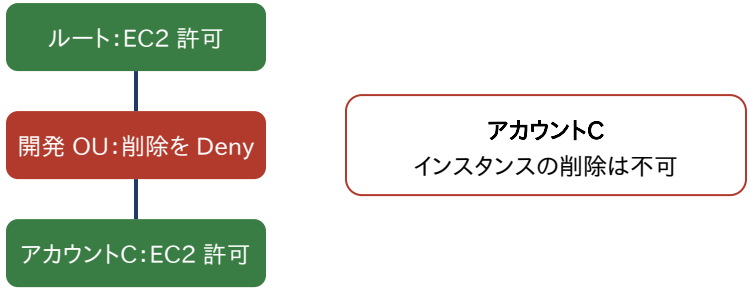
SCP の評価：Allow は全階層、Deny はどこか1つ

許可：経路のすべてに Allow が要る



FullAWSAccess：組織を作ると、すべてのルート・OU・アカウントに自動で付く「全部許可」の SCP。外して代わりの許可を付けないと、メンバーアカウントのすべての操作が失敗する。

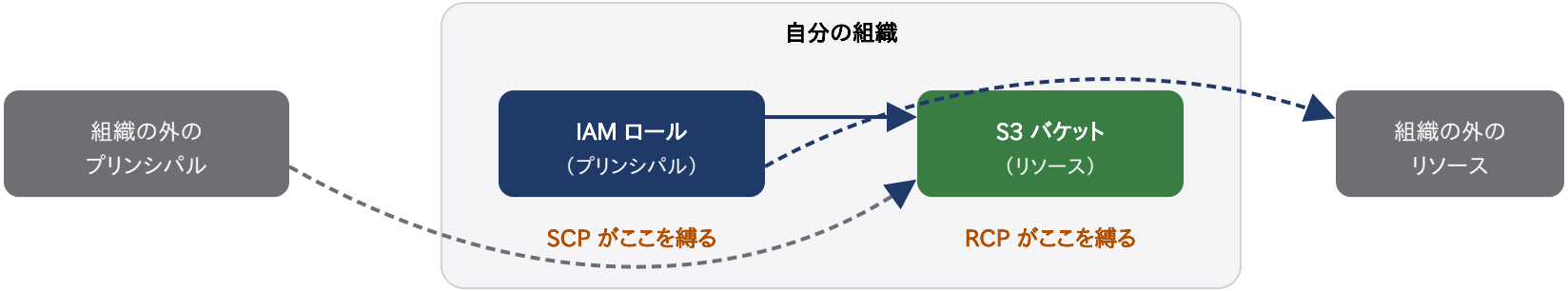
拒否：経路のどこか1つの Deny で決まる



2つの書き方：FullAWSAccess を残して Deny を足す（拒否リスト）か、FullAWSAccess を外して必要なサービスだけ Allow する（許可リスト）。

出典：SCP 評価（SCP と Allow の連携の仕組み・SCP と Deny の連携の仕組み・SCP の使用戦略）。図の組織とポリシーは Claude が作った例

SCP と RCP：守る向きがちがう



	SCP	RCP
縛るもの	自分の組織のプリンシパルが「何をできるか」（相手のリソースがどこにあっても）	自分の組織のリソースに「だれが何をできるか」（組織の外の人も含む）
こんなとき	社員が使えるリージョンやサービスを限る	組織の外からバケットに触らせない
共通	権限は与えない。管理アカウントには効かない。Organizations の「すべての機能」で使う	

出典：リソースコントロールポリシー (RCP)（「組織のメンバーアカウント内の IAM プリンシパルのアクセス許可を制限する必要がある場合は、SCP を使用します。」）

Control Tower：安全なマルチアカウント環境をすぐ作る

機能	中身
ランディングゾーン	ベストプラクティスに沿って設計された複数アカウントの環境（OU・アカウント・ユーザーなど）
コントロール	環境全体を統制するルール（ガードレールとも呼ぶ）。OU 単位で効く
Account Factory	承認済みの設定で新しいアカウントを作るテンプレート（Service Catalog の上に作られている）
ダッシュボード	アカウント・有効なコントロール・違反の状況を見る

Control Tower は Organizations・Service Catalog・IAM Identity Center などを組み合わせて動かす。

コントロールのふるまい

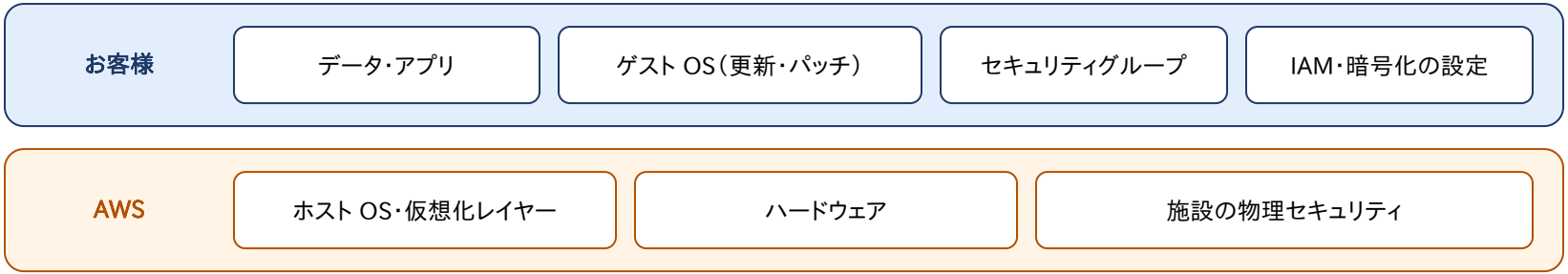
種類	何をする	実装
予防	違反になる操作を許さない	SCP・RCP・宣言型ポリシー
検出	違反を見つけて知らせる	AWS Config ルール
プロアクティブ	作る前に調べ、違反なら作らせない	CloudFormation フック

指針（ガイダンス）は別の分類で、必須・強く推奨・選択の3つ。

> **本番の言い回し：**「最小の運用の手間で、ガバナンスの効いた複数アカウントの環境を用意」→ Control Tower。

出典：AWS Control Tower とは（機能）／Control behavior and guidance（「The detective controls are implemented using AWS Config rules.」）

責任共有モデル：どこまでが AWS で、どこからが自分か



範囲はサービスで変わる：EC2 のようにサーバーを借りる形ほどお客様の範囲が広く、マネージドサービスほど AWS が多くを受け持つ（運用の負担が減る）。

ひっかけ：「EC2 の OS のパッチは AWS が当てる」は誤り。ゲスト OS はお客様の責任。

出典：AWS ホワイトペーパー「責任共有モデル」（「お客様の責任範囲は、使用するサービス、IT 環境へのサービス統合、および関係法令に応じて異なります。」）

第3章

ID の連携（フェデレーション）

人には IAM ユーザーを作らない。外の ID でサインインして、ロールの一時的な鍵を使う。

だれを、どれでつなぐか

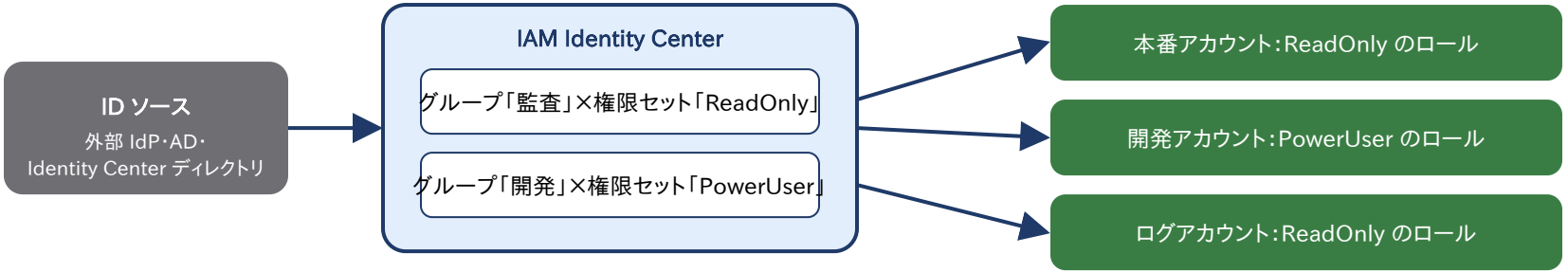
フェデレーション	アカウント	対象	ID ソース
IAM Identity Center	Organizations の複数のアカウント	社員（ワークフォース）	SAML 2.0・マネージド Active Directory・Identity Center ディレクトリ
IAM	単一のスタンドアロンアカウント	短期間の小規模な利用の人・マシン	SAML 2.0・OIDC
Cognito ID プール	どちらでも	AWS のリソースを使うアプリの利用者	SAML 2.0・OIDC・ソーシャル（OAuth 2.0）

標準	IAM で使う STS の API	代表的な使い方
SAML 2.0	`AssumeRoleWithSAML`	社内の IdP（AD FS など）の社員
OIDC	`AssumeRoleWithWebIdentity`	GitHub Actions など AWS の外のワークロード

AWS のおすすめ：人間のユーザーには IAM ユーザーを個別に作らず、ID プロバイダーとのフェデレーションを使う。組織で一元管理するなら IAM Identity Center。

出典：ID プロバイダーと AWS とのフェデレーション（IAM フェデレーションタイプの表。表は簡単にした）／IAM でのセキュリティのベストプラクティス

IAM Identity Center と権限セット



割り当てると Identity Center が各アカウントにロールを作る（構成は Claude の例）

用語	決まり
権限セット	IAM ポリシーをまとめたテンプレート。AWS 管理・カスタマー管理・インライン・職務機能のポリシーを入れられ、境界も付けられる。1人に複数を割り当てられる
ID ソース	組織に1つ。外部 IdP（Okta・Entra ID など）、Active Directory（オンプレミスか AWS Managed Microsoft AD）、Identity Center ディレクトリ（既定）。Simple AD は不可

出典：権限セットを使用して AWS アカウントを管理する／ID ソースを管理する（「ID ソースは AWS Organizations で組織あたり 1 つのみ持つことができます。」）

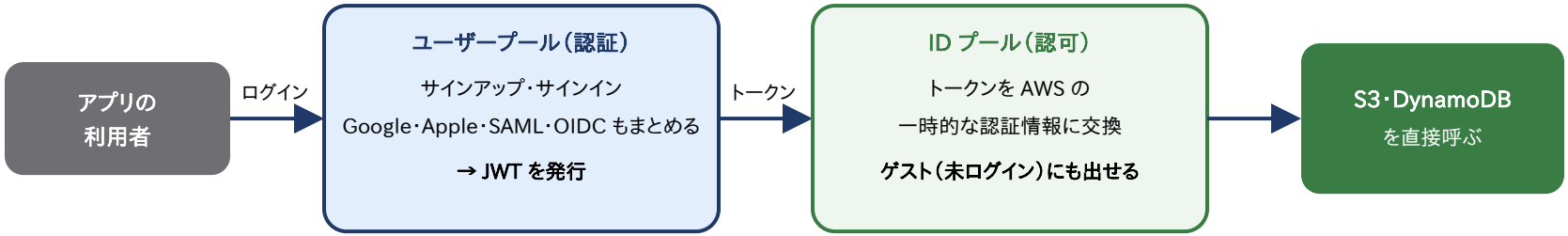
Active Directory を AWS で使う3つの形

	AWS Managed Microsoft AD	AD Connector	Simple AD
中身	AWS が管理する本物の Microsoft AD	オンプレミスの AD へ問い合わせを転送するゲートウェイ	Samba 4 の AD 互換ディレクトリ
ユーザーの置き場所	AWS の中のドメイン	オンプレミスの AD のまま（キャッシュしない）	AWS の中
配置	VPC の複数の AZ にドメインコントローラーのペア	オンプレミスのドメインと1対1	—
オンプレミスとの信頼関係	**結べる**	（AD そのものに転送する）	—
ほかのアカウントと共有	**できる**	**できない**	—
向いている場面	SharePoint・.NET・SQL Server など AD 対応アプリを AWS で動かす	今の AD のアカウントのまま AWS にサインイン	新しい顧客には提供されていない

選び方：「AWS の中に AD のドメインが要る」→ Managed Microsoft AD。「ユーザー情報を AWS に置かずに今の AD を使う」→ AD Connector。

出典：AWS Managed Microsoft AD／AD Connector（「AD Connector を他の AWS アカウントと共有することはできません。」）／Simple AD（「Simple AD は新規顧客に公開されなくなりました。」）

Cognito：アプリの利用者の「だれか」と「何を使えるか」



2つは別々にも組み合わせても使える。API Gateway の API だけならユーザープールの JWT で足りる

聞かれ方	答え
会員登録・ログイン画面・ソーシャルログインを付けたい	ユーザープール
アプリから S3 に直接アップロードさせたい（鍵を埋め込まずに）	ID プール
ログインしていない人にも一部のデータを読ませたい	ID プールのゲストアクセス
社員が組織の AWS アカウントを使う	Cognito ではなく IAM Identity Center

出典：Amazon Cognito とは（「このユーザーは誰ですか? (認証)」「このユーザーはどの AWS リソースにアクセスできますか? (認可)」）／Amazon Cognito アイデンティティプール

まとめ

組織
OU で分け、OU にポリシー。管理アカウントには SCP が効かないので作業に使わない

SCP・RCP
上限だけ。Allow は全階層、Deny はどこか1つ。SCP＝自分の人、RCP＝自分のリソース

Control Tower
ランディングゾーン・コントロール（予防・検出・プロアクティブ）・Account Factory

フェデレーション
社員＝Identity Center＋権限セット。AD＝Managed AD か AD Connector。アプリ＝Cognito

こんな要件なら	答え
メンバーアカウントで特定の操作を絶対にさせない	SCP で Deny
組織の外から自社のリソースに触らせない	RCP
ガバナンス済みの複数アカウントをすぐ用意	Control Tower
社員が今の IdP で複数アカウントにサインイン	IAM Identity Center
今の AD をそのまま使い、AWS にユーザーを置かない	AD Connector
アプリの利用者に S3 を直接使わせる	Cognito ID プール

> 次の #03 では、VPC のセキュリティグループ・ネットワーク ACL と、WAF・Shield などの外からの攻撃への守りを扱う。

出典：このPDFの各ページの資料